Supplementary Material: OTA-Shield

Philip Akekudaga[a], Simon Wewoliamo Kuseh[b] and Mubarak Hussein[c]

[a] University of Rhode Island, Kingston, RI, USA
[b] Affiliation to be provided,
[c] University at Albany, SUNY, Albany, NY, USA

ARTICLE INFO

Keywords:
Supplementary material

ABSTRACT

This document provides supplementary figures, tables, and methodological detail supporting the main paper: per-trial results, the first-contact recall taxonomy, build provenance, the statistical methodology, per-component resource placement, and the boundary and capacity floats referenced from the evaluation.

S1. Build provenance and the R5-gating revision

The results in this paper were collected on two successive binaries, and this appendix records which experiment ran on which so that each number can be tied to a fixed configuration. The deployed build gates the fleet-fanout counter (R5) on the unauthorized-source flag (`r2_fired`) and arms the per-source `hold_armed_reg` gate only on R5; because R5 sits behind the terminal R2 drop, that gate is inert on reachable input (§6.4, §7.2). An earlier un-gated build armed the per-source gate on *any* rule fire. On that build a compressed benign rollout that tripped the per-BMS replay rule (R1) would arm the gate and drop the source's subsequent packets at line rate before the arbiter could clear them, producing benign-rollout false positives. Restricting the gate's arming to R5 removes this behavior, and E12, E19, and E19' were re-measured on the deployed build, where they report zero benign-rollout false positives (§6.3, §6.4).

One consequence of the revision is the rollback recall the deployed build reports. The un-gated build recorded a near-perfect rollback recall, but that figure was inflated: the per-source gate incidentally dropped first-contact rollbacks that R6 itself cannot catch, because a first contact to a BMS has no stored version high-water mark. On the deployed build those cold-start cases surface as the gap between strict recall (0.857, counting first-contact events as misses) and lenient recall (0.970); we report the strict figure (§6.4, Appendix B).

The five-state lifecycle matrix (E22, §7.7) was originally completed only on the un-gated binary, where the per-source gate pre-empts the arbiter (152 of 160 benign rollout events dropped, a 95% false-positive rate). We re-ran the in-scope active-authorized state on the deployed gated build (0 false positives across 80 events, confirming the fix); the remaining states probe off-parameter authorized operation that the gated build does not quarantine (§7.7), and a containment matrix that also exercises a per-source hold role would require the 5-tuple-indexed hold register of §7.2 behind a P4 recompile. The integrity and freshness lifecycle failure modes are covered by E12b (§6.3). Table S1 summarizes the per-experiment configuration.

The override table is 5-tuple-keyed on the deployed build throughout (§6.7); E13 additionally characterizes the optional source-IP aggregation variant. E7b was re-run on the deployed gated build (§6.5): over the 8 h trace it records 0 benign false positives and catches all 100 rollback attacks, so it now reports on the deployed binary rather than an un-gated auxiliary run.

S2. Supplementary figures and tables

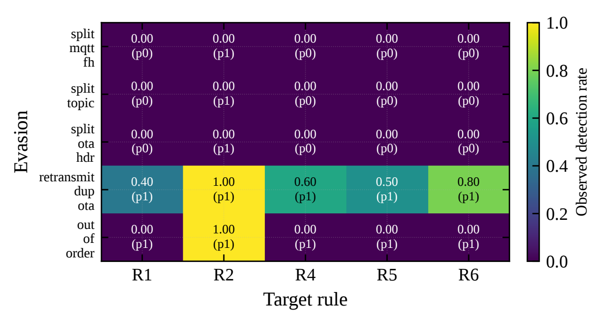

Figure S1: TCP-segmentation evasion (E23): observed per-cell drop rate over 10 trials/cell (250 trials), each cell reset-isolated; cell text is observed rate (predicted in parens). Header-split evasions defeat every rule including the source-keyed R2; only `retransmit-dup` (intact PUBLISH on the wire) yields parse-dependent detection, and only probabilistically. The R5 column does not exercise genuine fanout (single-PUBLISH base attack) and is shown for completeness.

References

[1] Qinwen Hu, Se-Young Yu, and Muhammad Rizwan Asghar. Analysing performance issues of open-source intrusion detection systems in high-speed networks. *Journal of Information Security and Applications*, 51:102426, 2020. doi: 10.1016/j.jisa.2019.102426. URL `https://doi.org/10.1016/j.jisa.2019.102426`. Quantifies Snort/Suricata drop behavior at 1-40 Gbps; AF_Packet reaches 60 Gbps before collapse.

Table S1

Per-experiment build provenance. "Deployed gated" is the final binary (R5 r2-gated, per-source hold gate inert, 5-tuple-keyed override table); "un-gated" is the earlier binary used before the R5-gating revision. The last column marks whether the result is part of the deployed-build story or is auxiliary/motivating only.

Experiment(s)	Binary	R5 gating	Deployed story
E1, E2, E6, E8, E14	deployed gated	r2-gated	yes
E4 (arbiter ablation)	deployed gated	r2-gated	yes
E12, E12b	deployed gated	r2-gated	yes
E19, E19'	deployed gated	r2-gated	yes
E9, E21, E23, E20	deployed gated	r2-gated	yes
E10 (incl. symmetric)	deployed gated	r2-gated	yes
E11, E13, E18	deployed gated	r2-gated	yes
E7b (long-horizon)	deployed gated	r2-gated	yes
S1, S2 (200-BMS)	earlier binary	n/a	scope only (cap-limited)
E22 active-authorized	deployed gated	r2-gated	yes (confirms fix)
E22 full matrix	un-gated	ungated	motivating only

Table S2

Rollout-Authorization Table fields. The manifest is a per-rollout JSON object loaded by the controller; a HOLD packet passes only when every condition matches.

Field	Policy semantics
`authorized_source_ips`	Allow-list of IPv4 addresses permitted to originate firmware PUBLISHes for this rollout.
`target_bms_list`	Allow-list of destination BMS IPs within scope of the rollout.
`valid_window_start/end`	UTC wall-clock window during which the rollout is active.
`expected_payload_size_range`	Inclusive byte range for advertised firmware size.
`expected_firmware_version`	Version number reported in the OTA header for control-plane sanity check.
`max_concurrent_targets`	Enforced per-rollout cap on the number of concurrent active sessions a rollout may hold; the controller denies admission beyond it (0 = unlimited).
`rollback_window`	Optional {`min_version`, `max_version`} pair authorizing a rollback range for this rollout (see §4.4.2). Default-absent: R6 remains a terminal rule.

Table S3

Reference-channel parser portability (E18) across the 8-variant MQTT-parameter sweep on the deployed parser. PARSED = the parser extracted a valid OTA header; PARSER-MISS = the packet was classified as non-OTA and forwarded unflagged. No variant is dropped; the determining factor is the 32-byte topic slot, not QoS or the retain flag.

Variant	Parameters	Outcome
baseline	topic=32 B, QoS=1, retain=0	PARSED
QoS=2	topic=32 B, QoS=2, retain=0	PARSED
retain=1	topic=32 B, QoS=1, retain=1	PARSED
QoS=0	topic=32 B, QoS=0, retain=0	PARSED
short topic	topic=16 B, QoS=1, retain=0	PARSER-MISS
long topic	topic=64 B, QoS=1, retain=0	PARSER-MISS
QoS=0, short	topic=16 B, QoS=0, retain=0	PARSER-MISS
QoS=0, long	topic=64 B, QoS=0, retain=0	PARSER-MISS

Table S4

50-BMS vs. 200-BMS precision and F_1. Recall is 1.000 across the 200-BMS replays (S1, S2); the 50-BMS E8 row reflects nine near-threshold R1 misses (recall 0.992). No rollback attempt is missed at either scale. The precision collapse at 200-BMS is attributed to the 64-entry controller/manifest BMS cap. The data-plane `bms_ip_to_idx` table is itself compiled at 128 entries (Table D.1), so legitimate packets addressed to BMS 65–200 are unmapped and take the fail-closed DROP path.

Experiment	Fleet	Precision	Recall	F_1
E8 (50-BMS headline)	50	1.000	0.992	0.996
S1 (200-BMS, det.)	200	0.195	1.000	0.327
S2 (200-BMS, stoch.)	200	0.292	1.000	0.453

Table S5

CPU IDS baselines on identical traffic (E10), on the E1 PCAP replay (90 events: 60 attack + 30 legitimate). Variants (i)–(iv) are CPU-IDS configurations; variants (v) and (vi) post-process variants (i) and (iii)'s alerts respectively through the same RAT arbiter OTA-Shield uses in-band (the apples-to-apples controls).

Variant	Prec.	Recall	Acc.	TP	FP
(i) Suricata min-effort	N/A	0.000	0.333	0	0
(ii) Suricata stateful	0.691	0.783	0.622	47	21
(iii) Suricata permissive	0.667	1.000	0.667	60	30
(iv) Zeek domain-aware	0.698	1.000	0.711	60	26
(v) Suricata + RAT	N/A	0.000	0.333	0	0
(vi) Suricata permissive + RAT	1.000	0.500	0.667	30	0

Table S6

Defence-in-depth coverage. Each layer catches a different fraction of the attack space; OTA-Shield is one of the three, not a replacement for the others.

Layer	What it catches
Endpoint signing (SUIT/Uptane)	Unsigned or mis-signed firmware at the BMS, regardless of how it arrives. Blind to *signed-but-malicious* firmware (stolen signing key) and blind to in-transit fanout.
OTA-Shield data plane	Naive coordinated campaigns (A1–A4 at their designed thresholds, plus A5 rollback via R6 and Gate B) at the network aggregation point. Blind to shaped adversaries that stay inside rule blind zones (E21); requires placement after TLS/VPN termination (§7).
Operator rollout dashboard	Slow-drift campaigns visible over hours to days through fleet-version skew. Too slow to stop a minutes-scale attack in flight.

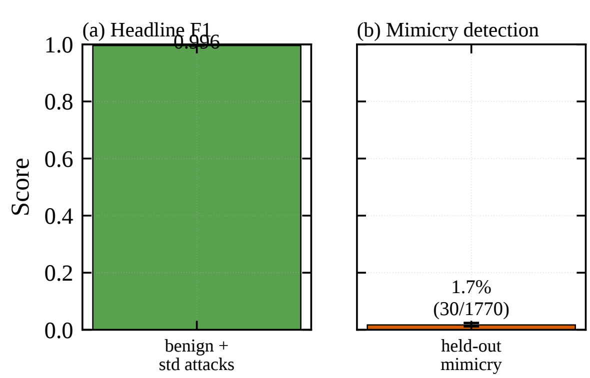

Figure S2: The two headline numbers, shown co-equal on a common $[0, 1]$ scale: (a) naive fleet-fanout detection $F_1 = 0.996$ (E8) versus (b) adaptive-mimicry coverage 1.7% (E21). The headline applies to the designed naive family; an adversary who reshapes cadence faces the right-hand number.

Table S7

Rule fires per mimicry strategy (E21) under per-strategy isolation, summed over 30 campaigns (1770 attack events total). Each strategy is designed to evade a specific data-plane rule; "caught" counts events the controller dropped, "missed" counts everything else. Under isolation, only *R1-late* produces any drop; every sub-threshold strategy evades entirely. Missed events escape the data plane and would need control-plane or endpoint recovery.

Strategy	N	R1	R2	R4	R5	caught	missed
fanout-sub	720	0	0	0	0	0	720
fanout-three	540	0	0	0	0	0	540
R4-deadzone	90	0	0	0	0	0	90
combined	360	0	0	0	0	0	360
R1-late	60	30	0	0	0	30	30
Total	1770	30	0	0	0	30	1740

Table S8
Tofino resource footprint of the evaluated build, with rough comparison to a CPU-based alternative on the same traffic. Dollar-per-BMS-year assumes a five-year amortization of a USD 20 k switch over a 50-unit fleet.

Cost dimension	OTA-Shield (Tofino 1)	Suricata (Xeon Gold)
MAU stages used	12 of 12 (Table D.1)	n/a
SRAM for rule state	3 KB (R5 Bloom) + 0.5 KB (R1)	host RAM
Session table (fleet-wide)	512 KB (two 64 K × 32 bit)	host RAM
Power per Gb/s (amortized)	∼70 mW/Gb/s	∼5 W/Gb/s
Throughput headroom	measured 2,200 pps (generator-bound); ASIC 25 Gb/s link, unmeasured	40–60 Gb/s [1]
Hardware cost (list)	$20 k (32×100 GbE)	$8–12 k server
$/BMS-year (50-unit fleet)	≈$80	≈$40